Compliance Requirements Analysis

DeRexi • Financial-services readiness • October 20, 2026

1 Business overview and scope

DeRexi is a policy-governance assistant being developed for organizational use. It helps employees locate and understand policies, submit clarification requests, contact policy owners, exchange in-app messages, and initiate incident-assistance workflows. The target industry for this assessment is financial services; Orange Capital Bank is a fictional demonstration client.

Assessment boundary: DeRexi application features, user information, policy documents, employee questions, messages, administrative actions, and supporting storage/services. This is a planning-stage gap assessment, not a legal compliance certification.

2 Regulatory and framework analysis

Layer / source	What it means	DeRexi design implication
Legal applicability: GLBA	Financial privacy and safeguarding law; whether DeRexi itself is directly covered depends on its activities and regulatory status. Client contracts may impose service-provider duties.	Classify customer data; minimize collection; protect data access, transfer, storage, and disposal.
Industry examination guidance: FFIEC IT Handbook	Guidance used in examining technology governance, development, operations, and service-provider risk; not a standalone certification.	Document SDLC, change controls, access management, logging, vendor dependencies, and incident workflow.
Security management: NIST CSF 2.0	Voluntary cybersecurity framework: Govern, Identify, Protect, Detect, Respond, Recover.	Use the six functions to structure security reviews, testing, monitoring, and corrective actions.

3 Business process map (target workflow)

Employee request → Identity/role check → Policy search and AI response → Feedback or clarification → Policy-owner review / in-app message → Resolution and audit record

Process step	Business activity	Security/compliance checkpoint
1. Access	Employee opens DeRexi	Authenticate user; enforce authorized roles (GLBA safeguard concept / NIST Protect).
2. Intake	Employee submits a policy question	Validate and limit input; avoid unnecessary sensitive data (NIST Protect; FFIEC development practices).
3. Answer	Application retrieves policy and produces guidance	Apply document permissions; show source references; handle no-match safely (NIST Protect / Govern).
4. Escalate	Employee asks for clarification or reports concern	Route only to appropriate owner; preserve confidentiality (FFIEC operational risk / NIST Respond).
5. Close	Owner responds; system records action	Maintain trustworthy records, review incidents and improve controls (NIST Detect / Respond / Recover).

4 Compliance requirements and gap analysis

Status key: Present = capability reported in the project; Partial = exists but security assurance is unverified; Planned = additional implementation or evidence needed.

ID / priority	Requirement and framework link	Current evidence / status	Next action
R1 / High	Role-based access to policies, messages, and owner functions • GLBA-aligned safeguards / NIST PR.AA	Partial: roles/personas exist; enforcement not verified	Test employee, owner, and admin permissions; capture access-denied results.
R2 / High	Protect sensitive stored and transmitted data • GLBA safeguards / NIST PR.DS	Planned: HTTPS and encryption evidence not established	Document TLS deployment, secret management, data classification, and retention.
R3 / High	Validate all user-supplied input • FFIEC DA&M / NIST Protect	Partial: prior SSD testing showed HTTP 422 rejection; user-facing error needs improvement	Test questions/messages and display a plain-language error while logging safely.
R4 / Medium	Trace policy changes, clarifications, and messages • FFIEC / NIST Govern, Detect	Partial: policy/version and messaging features discussed; audit completeness unverified	Define logged events, actors, timestamps, retention, and admin review.
R5 / High	Incident intake and escalation • FFIEC operations / NIST Respond	Partial: incident assistance underway	Test escalation paths and document response ownership and notifications.
R6 / Medium	Secure change and supplier management • FFIEC DA&M / NIST Govern	Planned: GitHub workflow exists; formal control evidence missing	Maintain code review/test checklist and inventory OpenRouter, Supabase, and hosting risks.

5 Recommended evidence and next steps

First, verify user authorization and input-validation behavior. Next, capture screenshots or test logs for rejected access, accepted/rejected questions, message routing, and incident escalation. Then document the hosting/HTTPS design, service providers, retention approach, and change-control workflow. Mark a requirement “verified” only after repeatable evidence exists.

Important limitation: GLBA duties vary by entity and supervisory authority. A financial institution must determine which rules apply to its own operations; DeRexi should support those requirements through technical and contractual controls.

Official reference sources

FTC — Gramm-Leach-Bliley Act: https://www.ftc.gov/business-guidance/privacy-security/gramm-leach-bliley-act

FTC — Safeguards Rule overview: https://www.ftc.gov/business-guidance/resources/ftc-safeguards-rule-what-your-business-needs-know

FFIEC — IT Examination Handbook (Development, Acquisition, and Maintenance): https://ithandbook.ffiec.gov/it-booklets

NIST — Cybersecurity Framework 2.0: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf

6 Basic compliance program plan

Objective: establish a repeatable process to identify applicable obligations, protect client policy information, verify security safeguards, record evidence, and improve gaps before a financial-institution deployment. This is a proposed program, not an assertion of existing certification.

Organizational roles and responsibilities

Proposed role	Primary responsibility	Evidence / deliverable
Product / business owner	Approve scope, risk decisions, budget, client commitments and launch gates.	Approved scope and risk register
Compliance lead (role; may be shared in MVP)	Maintain GLBA applicability review, FFIEC/NIST crosswalk, requirements and policy review cycle.	Control register and review log
Security / technical lead	Implement safeguards, manage access and vulnerabilities, verify encryption and logging.	Configurations and security test results
Policy owner / data steward	Approve policy content, classify documents and resolve clarification requests.	Approval history and content change log
Application administrator	Provision/deprovision users, assign roles and review access and incident alerts.	Access-review records and incident log
Independent reviewer / tester	Test controls and document failures and corrective actions; role should be separated when feasible.	Signed test report and remediation tickets

For the capstone, one developer may perform several roles. Document who performed each activity; separate review or test approval where feasible. Orange Capital Bank remains an illustrative client, not a verified deployment.

Proposed implementation timeline

Phase	Work to complete	Exit evidence
Week 1 — Scope & assess	Confirm regulated-client use cases, data inventory and GLBA applicability assumptions; map FFIEC and NIST expectations.	Approved scope, requirement register, process map
Week 2 — Design controls	Define role permissions, question validation rules, audit events and security acceptance criteria.	Control specifications and test cases
Weeks 3–4 — Implement	Enforce server-side authorization and input validation; improve friendly errors and audit capture.	Code changes, configuration and test environment
Week 5 — Verify & remediate	Run positive/negative security tests; correct failures, retest and review privileged access.	Test results, evidence, tracked findings
Week 6 — Review & maintain	Approve residual risks; set monthly access checks and quarterly control review; collect baseline documentation.	Sign-off, monitoring calendar, versioned documentation

7 Two documented compliance controls

These are proposed application controls aligned to relevant GLBA safeguards concepts, FFIEC supervisory guidance and NIST CSF 2.0 categories. They are not sufficient by themselves to establish full regulatory compliance.

Control C-01 Role-based access control (RBAC)

Purpose: limit policy viewing, editing, messaging and governance actions to authorized users. Owner: Security / technical lead; administrator performs access reviews. Status: planned / requires verification of enforcement for all roles.

Implementation procedure:

1. Define a permission matrix for Employee, Policy Owner and System Admin (and HR if included).
2. Verify user identity and role in the backend on every protected request; never trust a UI-only role check.
3. Restrict policy updates, administration, message recipient access and incident records to permitted roles; deny by default.
4. Log meaningful authorized and denied actions without exposing private document content in logs.
5. Review active users and permissions monthly; remove access promptly when no longer needed.

Testing method and pass criteria:

- Create test accounts or controlled test fixtures for each role; the capstone may simulate roles without relying on fictitious Supabase logins.
- Positive test: each role can perform its explicitly permitted action (PASS if allowed).
- Negative test: Employee attempts admin-only edit, another user's private message, and privileged endpoint directly (PASS only if server rejects with 403/appropriate denial and data is not returned).
- Verify deny events in a redacted log and confirm revoking privileges blocks the next request. Save screenshots, sanitized HTTP responses and test date.

Control C-02 Input validation and safe error handling

Purpose: prevent malformed or unexpected questions/fields from reaching sensitive workflows and avoid exposing internal details. Owner: Security / technical lead. Status: partial evidence from an earlier SSD 1 test; DeRexi-specific implementation and repeat testing remain outstanding.

Implementation procedure:

6. Define accepted field types, maximum lengths, required fields, and allowed values for questions, feedback and message creation.
7. Enforce the rules in the backend (frontend checks may improve usability but are not security boundaries).
8. Normalize or reject unsupported inputs; handle unexpected errors without revealing stack traces, credentials or backend internals.
9. Return a clear user-facing message and record a sanitized error category for troubleshooting.
10. Maintain automated tests for accepted and rejected payloads; re-run after relevant code changes.

Testing method and pass criteria:

- Positive tests: valid policy question and valid message are accepted and handled correctly.
- Negative tests: blank or overlong questions, wrong data types, missing required fields and unexpected fields are rejected with appropriate 4xx responses.
- Check that no sensitive implementation details appear in the user interface or API response, and no invalid record is stored.
- Evidence: test-case table, sanitized screenshots of friendly errors, automated-test output and re-test log. Prior observation of HTTP 422 alone does not prove every DeRexi input is protected.

8 Control verification record (fill in after testing)

Control	Test date	Observed result	Pass / fail	Evidence ID
C-01 RBAC	Pending	Not yet verified	Pending	—
C-02 Validation	Pending	DeRexi-specific retest needed	Pending	—

Acceptance and follow-up: record defects, responsible owner, target fix date, retest and final approval. Do not mark a control "implemented" or "passed" until the application has been tested and evidence retained.